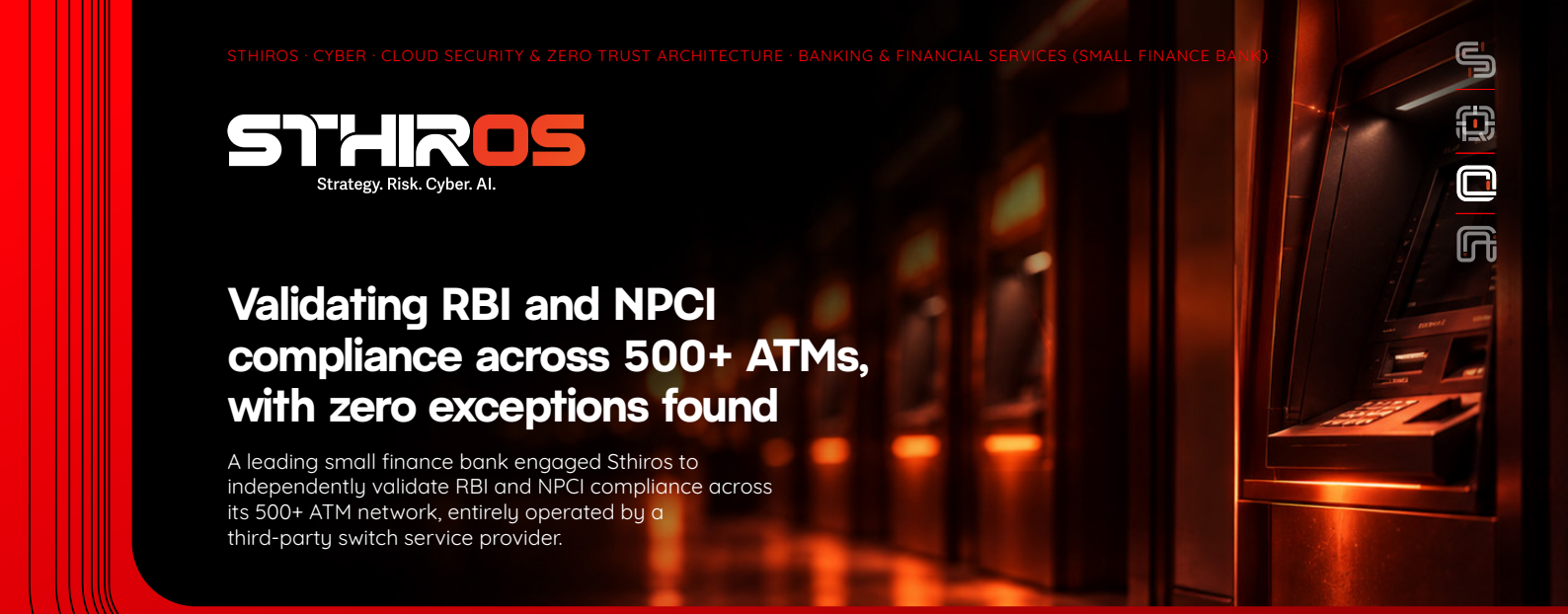
STHIROS
Strategy. Risk. Cyber. AI.



# Validating RBI and NPCI compliance across 500+ ATMs, with zero exceptions found

A leading small finance bank engaged Sthiros to independently validate RBI and NPCI compliance across its 500+ ATM network, entirely operated by a third-party switch service provider.

| Client | Service | Sector | Geography |
|---|---|---|---|
| **A Leading Small Finance Bank** | **ATM Operations & Infrastructure Compliance Audit, Vendor Assessment** | **Banking & Financial Services (Small Finance Bank)** | **India** |

## The Challenge:

### When the vendor operates the ATMs, but the bank carries the accountability

This bank had outsourced its ATM switch operations entirely to a third-party provider. Under RBI's regulatory framework, the bank remained fully accountable for every control regardless of who operated it, and that accountability gap defined this engagement.

#### No Independent Line of Sight

With the ATM switch entirely managed by a third party, the bank had no structured framework to independently confirm the vendor was operating within RBI and NPCI expectations.

#### Fragmented Multi-Framework Compliance

The bank was simultaneously subject to 5 regulatory frameworks across RBI and NPCI, with no consolidated, independent view existing across any of them.

#### Regulatory Inspection Readiness

As a Small Finance Bank under active RBI oversight, an unvalidated vendor arrangement covering 500+ ATMs was an unacceptable exposure at any point of supervisory inspection.

#### Inability to Verify Vendor Claims

Data security, DR readiness, access management, encryption key integrity, and SLA performance were all reported by the vendor, with no independent way to confirm them in practice.

## The Solution:

### Three structured domains, not a compliance tick-box

Sthiros ran a full independent validation across ATM infrastructure, operations, and general controls, confirming every claim the vendor had made rather than accepting it on paper.

138 checkpoints were reviewed across the complete ATM ecosystem, including a 2-3 day physical inspection of HSM, disaster recovery, and physical security.

## The Methodology

1

### ATM Infrastructure

Switch administration, HSM and encryption key lifecycle, card security, backup controls, disaster recovery, uptime monitoring, and Green PIN generation assessed against RBI's full regulatory suite.

2

### ATM Operations

Settlement and operations compliance validated in full against NPCI's NFS Operating and Settlement Guidelines V2.6.

3

### General Controls

Vendor due diligence, contractual and SLA compliance, and IT general controls, including access, change, incident, patch management, VAPT, and BCP, assessed end-to-end.

## What This Means

**Own the risk you outsource.**

**Verify vendors, don't trust them.**

**Walk into inspections ready.**

## Outcomes

500+

**ATMs covered**

The full network scale brought under one independent validation exercise.

138

**Checkpoints reviewed**

Across ATM infrastructure, operations, and general controls.

100%

**Compliance achieved**

Every control domain independently confirmed, with zero exceptions identified.

5

**Regulatory frameworks validated**

RBI Digital Payment Security Controls, Cyber Security for Third-Party ASPs, IT Outsourcing, ITGRC, and NPCI NFS V2.6.

## Get in touch

**Is your outsourced infrastructure validated, or just**

Speak to Sthiros about what an independent vendor compliance validation can unlock for your regulatory readiness.

Connect with us:
sthiros.com

STHIROS
Strategy. Risk. Cyber. AI.